



Universidad Nacional Autónoma de México



Facultad de Ingeniería

Alumno:

Lara Hernandez Angel Husiel - 320060829

Seguridad informatica basica

Grupo: 4

Semestre: 2027-1

Tarea 4

PumaHat Cybersecurity Week

Fecha de Entrega:

30 de Septiembre del 2026



Índice

1	Charlas asistidas	1
2	Experiencia personal y elementos a destacar de las presentaciones	1
2.1	Perspectivas diferentes en la ciberseguridad	1
2.2	Elementos a destacar	2
2.3	Del delito físico al delito digital: como piensa los atacantes y como anticiparse a ellos.	3
2.4	Terraforming the kill chain: de código a control	5
2.5	Elementos a destacar	6
	Referencias	7



1. Charlas asistidas

1. Perspectivas diferentes en la ciberseguridad. **Angel Samuel Resendiz Gonzales**
2. Del delito fisico al delito digital: como piensan los atacantes y como anticiparse a ellos. **Mauricio Alan Ilera Diaz**
3. Terraforming the kill chain: de codigo a control. **Diego Castro**

2. Experiencia personal y elementos a destacar de las presentaciones

2.1. Perspectivas diferentes en la ciberseguridad

Para esta primera ponencia, el expositor es un Shift Technology Officer, donde todo se centro en que saber las herramientas correctas no es lo mismo que saber explotar un sistema o una vulnerabilidad. Algo que cabe recalcar que me parecio curioso fue la mencion de los metaexploits para los principantes, que con un `sudo rm -rf /` se les engaña para que crean que estan haciendo, cuando de la nada les borran todo; y esto en mas de alguna ocacion lo he visto con personas que no conocen linux o que simplemente por la broma se les dice un `rm` es borras espacio, y es cierto lo que dice el ponente: es para atrapa bobos.

Despues paso a la parte de derecho informatico, donde lo que nos explico fue por medio de una analogia de una casa con todo abierto abierto, donde lo que nos decia es que uno puede verla, reportarla a la policia, pero, en el momento en que se mete un pie dentro de esa casa, ya se esta violando la ley; y esta analogia si es muy precisa, por que directamente esto lo podemos ver en el mundo del hacking etico, con lo que he llegado a ver de historias donde multan al hacker por avisar que existe una brecha de seguridad. esta analogia tiene sentido, y ya, aunque no tengo alguna experiencia personal sobre eso, esto me hace sentido con lo que he llegado a leer y ver.

Con esto tambien hablo del bug bounty, aclarando que cada programa de recompensas tiene limites muy especificos y que pasarse de esos limites ya es un delito.

Por ultimo, el tema que mas me llamo la atencion fue el tema del OSINT, donde el ponente nos dijo que muchos de los que apenas inician piensan que es nada mas meter un link a una pagina de IP logger y ya con eso se cree que tienen la ubicacion de alguien, pero que en realidad solo lo que regresan es la direccion del proveedor del internet, y esto, en lo personal, si me paso cuando recién empecé a investigar; escuchaba que con la ip de alguien ya se tenia practicamente todo, y al ponerme a investigar que la IP no coincidía con la ubicación de la persona, empecé a leer mas sobre el mismo tema y si dije que era una gran mentira lo que todos decían, por que al final de todo no esta completamente contado, por que, si bien es cierto que con la IP se puede llegar a una ubicacion aproximada, pero no es la ubicacion

exacta de la persona. Regresando con la ponencia, el mismo Angel nos dijo que llego a usar OSINT combinado con Have I Been Pwned y una pagina .onion para buscar contraseñas filtradas por dominio, incluso encontrando la suya propia filtrada, y esto me llamo mas la atencion por que esto en mas d euna vez me ha pasado con Apple y malwarebytes, que me avisan: tu contraseña se encontro en una filtracion de datos; y luego luego voy a cambiarla. Esto me hace hacer sentido con lo que decia el ponente.

Una cosa a recalcar es que al final hablo de la etica: que si a uno le confian una base de datos, no se debe caer en lo no etico de vender los datos de esa base por dinero, por que al final la libertad de una persona vale mas que cualquier sistema. Recomendo plataformas como Hack The Box y TryHackMe para practicar de forma legal.

2.2. Elementos a destacar

- El termino “atlapabobos” para describir a la gente que ejecuta comandos sin entender que hacen.
- La analogia de la casa con las puertas y ventanas abiertas, para explicar donde empieza el delito informatico.
- La explicacion de los limites legales de un programa de bug bounty y de que pasarse de esos limites ya es delito.
- Diferenciar entre el OSINT superficial, que son las paginas de IP, y el OSINT real con herramientas como Maltego.



Figura 1: Inicio de la conferencia



2.3. Del delito fisico al delito digital: como piensa los atacantes y como anticiparse a ellos.

En esta segunda charla, el expositor directamente empezo con la ponente Mauricio, que se nos hablo que era Chief Security; empezando la presentacion, inicio explicando la formula que da resultado al riesgo, donde lo importante para mi fue que empezo diciendo que esta formula tiene dos variables: una es la amenaza y la otra es la vulnerabilidad, donde sumadas dan el riesgo. El ponente empezo diciendo que como empresas casi siempre se invierte mas en los guardias, hacinedo referencia a la administracion de amenazas; no obstante, se deja de lado a la vulnerabilidad, que en resumidas cuentas somos nosotros o las personas que forman parte de la empresa. Esto, desde mi perspectiva y de lo que he llegado a ver en mi familia y en otras personas, es que es cierto; simplemente el ejemplo que puso el ponente fue los correos que engañan. Esto mas de una vez lo he tenido que ver en mi familia, donde sin saber da clic a enlaces que no son de confianza. Ahora bien, esto me dejo pensando en que, si bien esto pasa en mi familia donde ya trabajan, esto me deja diciendo que Mauricio tiene razon: la empresa en las que estan no contratan alguna empresa para solucionar estos problemas de vulnerabilidad, que facilmente se pueden solucionar con capacitaciones o concientizacion.

Ahora bien, la segunda formula fue la triada de deliciente, mercado y comprador, donde se explico que si se rompe cualquiera de los 3 no existe delito; esto por que es un ciclo sin fin: el deliciente vende en el mercado y el comprador compra, y si esto se llega a romper, el ciclo se acaba. nuevamente, esto, desde que lo he llegado a ver en filtraciones de juegos o hackeos a empresas de videojuegos, esto es cierto: mientras el deliciente vende el codigo del juego robado, existe un mercado por que es un juego oculto, y eso hace que exista el comprado; pero en algunos casos que nadie lo compra, simplemente la mercancia se queda estancada y ya no existe motivo para volver a atacar a la empresa.

Despues de esto explico lo del SID, que era la confidencialidad, integridad y disponibilidad, donde se nos dijo que era el pila de la seguridad, por que era lo que nos protegia. Asi que, con esto, el presento 3 modelos para poder armar una matriz de riesgo: una fue VIVA, otro fue CiberTac y el ultimo fue NIST. aunque anteriormente ya habia escuchado de la matriz de riesgo, esto en planificaciones de proyectos de software, no lo habia visto esto aplicado a la seguridad, lo cual hace que sea de suma importancia, por que si bien es cierto que cualquiera de los 3 es bueno, lo recomendable es que se utilicen los 3, esto para llegar a un riesgo inherente, y con esto poder llegar a un riesgo residual, y con esto poder llegar a un riesgo aceptable, donde el ponente nos dijo que el riesgo aceptable es aquel que la empresa esta dispuesta a aceptar en la mayoria de los casos, por que lo ideal es que no exista riesgos en nada.

Algo a recalcar que me parecio de suma importancia es que se nos dijo que esa matriz se tiene que revisar de 3 a 6 meses, esto por que en lo digital va evolucionando mas rapido, y esto es cierto, por que como lo vimos en la clase, con las vulnerabilidades, se encuentran un gran numero en tan pocos dias.

Por ultimo, la presentacion acabo con una conclusion particular, la cual nos puso una frase en las diapositivas, donde se nos puso que “La ciberseguridad no comienza cuando ocurre el ataque; comienza cuando somos capaces de anticiparlo”. esto me hizo mucho sentido, por que si durante el ataque empiezan a vulnerar nuestros equipos o informacion, y nosotros no somos capaces de antiiparlo, simplemente no vamos a poder hacer nada y, de cierta forma, la plabara ciberseguridad en ese conexto no tiene sentido. Empieza a tomar sentido cuando somos capaces tanto de anticipar el ataque como cuando somos capaces de reaccionar a el, por que una vez teniendo las capacidades de anticipar, nosotros ya no estamos protegiendo; ya estamos mas seguros de cierta manera. esto pasa igual con la seguridad fisica, por que nosotros sabemos que en algun momento nos pueden robar, lo que hace que se pueda anticipar y minimo tener alguna medida de contigencia.

Ahora bien, los elementos a destacar de todo esto fue:

- La formula de riesgo = amenaza + vulnerabilidad, y la explicacion de por que, como organizaciones se invierte mas en controlar la amenaza que la vulnerabilidad.
- La triada de delincuente, mercado y comprador.
- Los tres modelos para armar una matriz de riesgo: VIVA, CiberTAC y NIST.
- La recomendacion de revisar la matriz de riesgo cada 3 o 6 meses por la evolucion constante de los ataques.



Figura 2: Inicio de la conferencia

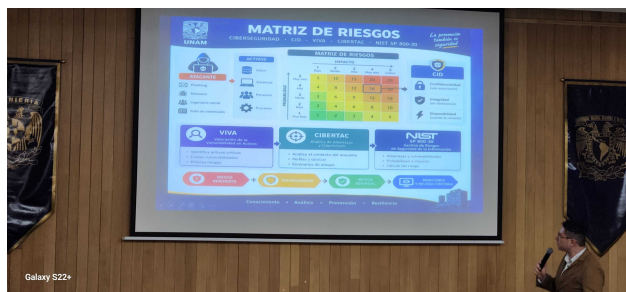


Figura 3: Matriz de riesgo

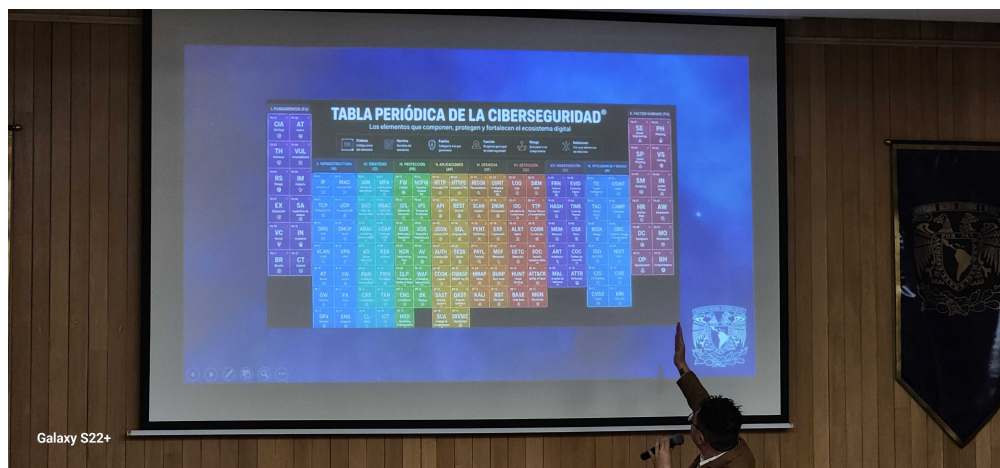


Figura 4: Tabla periodica de la ciberseguridad

2.4. Terraforming the kill chain: de código a control

En la última plática a la que pude asistir, fue dada por Diego Castro, en este caso su ponencia fue de como optimizar las operaciones ofensivas mediante infraestructura automatizada, el empezó hablando sobre las diferencias entre pentest y un ejercicio de red team, donde se nos explico que en el caso de el red team suele ser mucho mas confidencial, con menos personal de la organizacion y donde como tal, el objetivo es evadir al Blue Team o al SOC, el empezó a contar una anecdota de cuando empezó, donde el miedo principal era que lo detectaran, esto por que no se preocupaba lo suficiente por estar oculto, esto me recuerdo a lo que se vio en la primera conferencia donde se se nos decia un poco de los principantes, aunque como tal aqui no era poner solo comandos, esto me recuerdo a esta primera conferencia, donde como tal al ser nuevos, tanto tenemos miedo, como es mas facil caer en engaños y quedar mal, por que como el mismo Diego dijo, que el tambien tenia miedo a quedar mal si es que lo llegaron a descubrir.

Después de esto, ya paso directamente a la parte central de la presentación, donde se nos empezó hablando sobre el concepto de Infrastructure as Code (IaC), con dos tecnologías principales: Terraform, donde esta utiliza principalmente pluggins y APIs de proveedores de nube permite declarar el estado que se quiere y levantarlo con un solo binario, además de esto explico tambien el concepto de redirector como una maquina que actua de proxy, donde esta como tal lo que hacia era el filtrado del trafico entrante, esto si la conexion trae un user agent especifico y una llave configurados, se deja pasar como segura la conexion del C2, y si no, se redirige a un sitio señuelo que puede ser cualquier cosa, hasta la pagina del clima, esto se hace para para despistar al equipo de detección.

Además nos dio las diferencias entre esto y entre una infraestructura de phishing, donde en vez de establecer conexión con un equipo, lo que hace es recolectar credenciales directamente, y conto una anecdota de su primer ejercicio de phishing, donde uso una plantilla pero puro

html plano y puro, donde puso que se debía de actualizar la contraseña y en caso de que no se negaría el acceso al edificio, y aun así logro que cayera una persona, esto si nos damos cuenta se relaciona con la primera charla nuevamente donde de nuevo es muy fácil caer en engaños, con personas que no tienen la capacitación, donde con esto nos damos cuenta que el ponente de la primera charla tenía razón, con que las empresas no invierten en capacitación y concientización, y esto es un gran problema, por que si bien es cierto que se puede tener un gran sistema de seguridad, si no se tiene la capacitación de las personas, simplemente no sirve de nada, por que al final, la vulnerabilidad principal es el personal, tal y como dijo Diego que puedo hacer lo mismo.

2.5. Elementos a destacar

- Un ejercicio de red team, sobre todo en el nivel de confidencialidad y en el objetivo de evadir al Blue Team o al SOC.
- El uso de Infrastructure as Code (Terraform y Ansible) para automatizar el levantamiento, configuración y desecho de infraestructura ofensiva sin perder el control sobre ella.
- El redirector como proxy que filtra conexiones por user-agent y llave, redirigiendo todo lo demás a un sitio señuelo para despistar al equipo de detección.

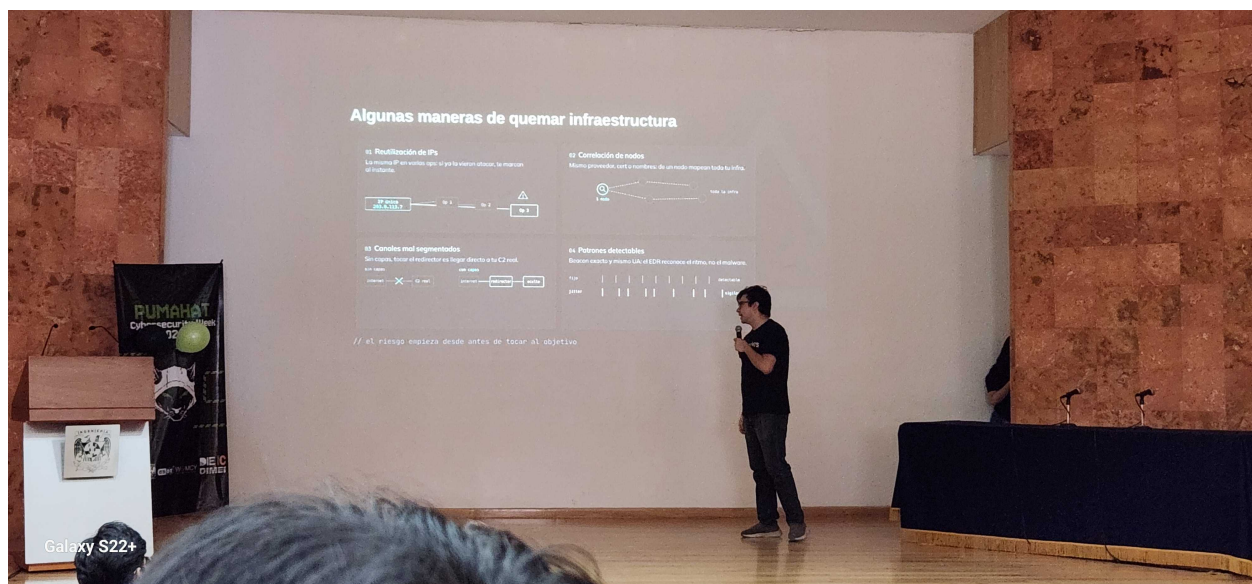


Figura 5: Manera de quemar infraestructura

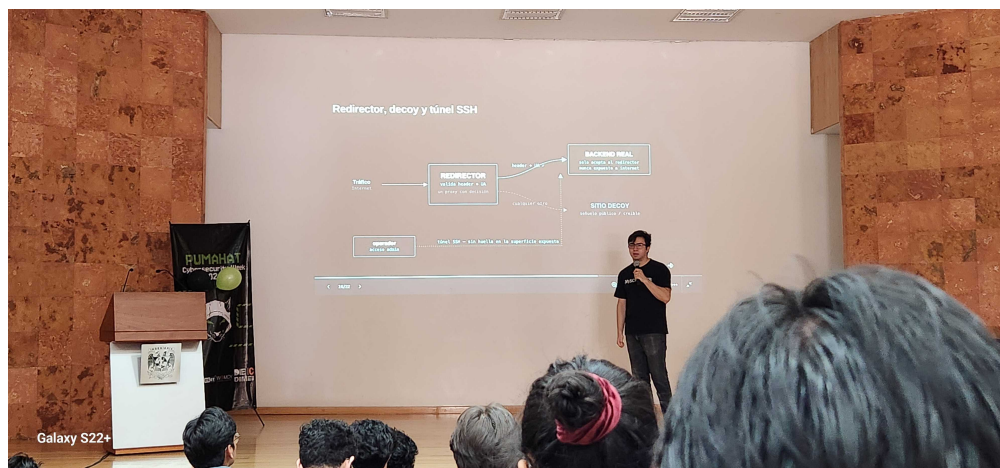


Figura 6: Redirector y sitio señuelo

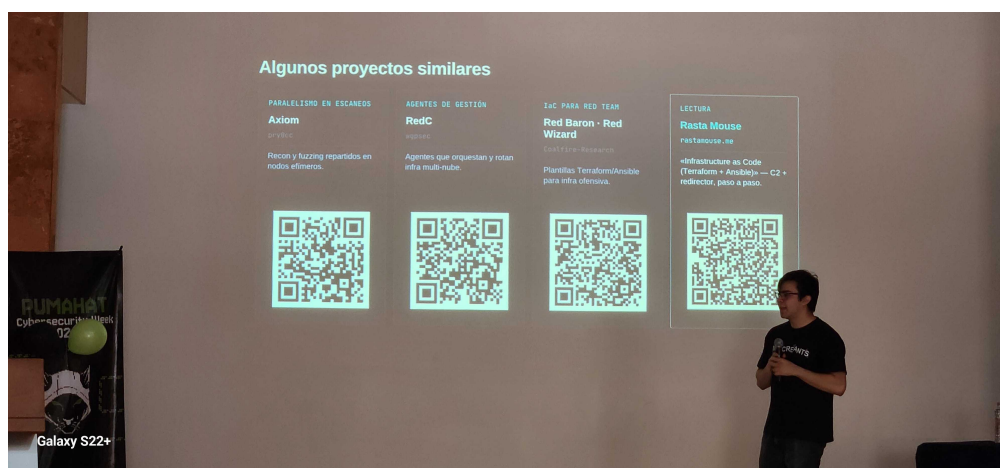


Figura 7: Final de la conferencia

Referencias

- Castro, D. (25 de Septiembre de 2026). Terraforming the kill chain : De código a Control [Presentación de conferencia]. *PumaHat Cybersecurity Week 2026*.
- Illera Díaz, M. A. (22 de Septiembre de 2026). Del delito físico al delito digital: ¿Cómo piensan los atacantes y cómo anticiparse a ello? [Presentación de conferencia]. *PumaHat Cybersecurity Week 2026*.
- Resendiz Gonzales, A. S. (22 de Septiembre de 2026). Seguridad informática desde perspectivas diferentes [Presentación de conferencia]. *PumaHat Cybersecurity Week 2026*.